INTRODUCTION

- Course code: **CYS 412**
- Course name: **IT AUDIT AND CONTROL**
- Course lecturer: **Miss KAPAPULA**
- Contact: kaela.kapapula@gmail.com
  kaela.kapapula@kmu.ac.zm

Course Structure

- Lectures (Theory)
- Laboratory Sessions (Hands-on)
- Assignments and Tests
- Final Examination

Course Overview

On completion of this course, students should be able to:

- Gain knowledge on security architecture (Policies, Standards, Procedures and Controls and,
- To be able to audit services in accordance with IT audit standards to ensure confidentiality, integrity and availability of information assets is provided

Assessment Breakdown

- Assignments: 20%
- Term Tests: 20%
- Final Exam: 60%

The difference between "**lecture**" and "**class**"

- **Lectures are usually more passive, while classes are more interactive**.
- In lectures, the instructor does most of the talking, while in classes, students have an opportunity to engage in conversations and activities with their peers.

Prescribed Textbooks

- Bouziane, A. (2026). Redefining Auditing in the Digital Era: Global Perspectives OnTechnology, Security, And Leadership.
- CyBOK. (n.d.). The Cyber Security Body of Knowledge. https://www.cybok.org/
- Davis, C., & Schiller, M. (2020). IT Auditing: Using Controls to Protect Information Assets.(3rd ed.). McGraw-Hill.
- Otero, A. R. (2018). *Information Technology Control and Audit* (5th ed.). Auerbach Publications. https://doi.org/10.1201/9780429465000

Expectations

- Attend lectures
- You must have a course outline to guide your studies
- You must make time to practice labs
- Take note of main points for reading/research later
- Take note of highted words, questions and resources
- Write your own notes about a topic. Taking pictures is NOT ALLOWED because this distracts others
- You should feel free to ASK questions where you are not clear

Recommended Textbooks

- Hall, J. A. (2015). Information Technology Auditing (5th ed.). Cengage Learning.
- ISACA. (2018). COBIT 2019 framework: Introduction and methodology.
- ISACA. (2024). CISA review manual (27th ed.).
- Jones and Ashenden. (2005). Risk Management for Computer Security: Protecting Your Network & Information Assets. (1st ed.). Butterworth-Heinemann/Elsevier.

Web Resources

- https://www.isaca.org/resources
- https://www.cybok.org/
- https://www.itil.com
- https://www.coso.org/guidance-on-ic
- https://www.iso.org/standard/81684.html

Lecture Objectives

- Understand the historical evolution of auditing
- Explain drivers of change in auditing
- Differentiate auditing and assurance
- Link auditing to governance, risk, and ICT

AUDITING, INTERNAL CONTROL AND IT GOVERNANCE

CYS 412: TERM 1

Evolution of Auditing and Assurance Services

- Understanding how auditing evolved into modern assurance
- Financial, ICT, and sustainability perspectives

Meaning of Auditing

- Auditing is an independent examination of financial statements, records, or operational processes.
- An auditor compares the actual "state of affairs" against a set of criteria (such as **IFRS-International Financial Reporting Standards)** to express an opinion on whether the information is a "true and fair" representation of reality.

Why Audits are needed

- **Operational Improvement:** Auditors often provide recommendations to strengthen internal controls and improve organizational efficiency.
- **Capital Market Stability:** Without audits, investors would be hesitant to provide capital, as they would have no way to verify the health of a company.

Why Audits are needed

Audits serve several critical functions in a modern economy:

- **Error and Fraud Detection:** They help identify mathematical mistakes, technical errors, or deliberate misappropriation of funds.
- **Compliance:** They ensure that an organization is following statutory laws, industry regulations, and internal policies.

Role of trust and accountability

Trust is the "oil" of the financial system. Since owners (shareholders) are often separate from the managers who run the business, a **principal-agent gap** exists.
Accountability: Audits hold management accountable for how they have used the resources entrusted to them.
Trust: By having a neutral third party verify the numbers, the audit bridge the gap of "information asymmetry," allowing stakeholders to trust the data provided by management.

Users of Audited Information

Different groups rely on the audit report for various decision-making purposes:
Shareholders/Investors: To decide whether to buy, hold, or sell shares in a company.
Lenders and Banks: To assess the creditworthiness of an entity before approving loans.

Definition of Auditing

- Independent examination of financial information
- Objective: express an opinion
- Performed by a qualified auditor
- Enhances credibility of reports

Users of Audited Information

Government and Tax Authorities: To ensure that the correct amount of tax is being declared and paid.
Employees: To gauge the stability and future viability of their employer.
Management: To confirm that their internal systems are functioning correctly and to identify areas for improvement.

Why Audits are needed

- **Verification of Accuracy:** Ensures that financial reports are free from material misstatements, whether caused by error or fraud.
- **Compliance & Regulation:** Confirms that the organization is adhering to statutory laws, tax regulations, and industry-specific standards.

Why Audits are needed

- **Risk Management:** Identifies weaknesses in internal controls and provides a roadmap for improving organizational efficiency.
- **Investor Confidence:** Acts as a "seal of approval" that allows the public to trust the financial health of an institution.

Characteristics of Early Audits

- 100% checking of transactions
- Fraud and error detection
- No formal standards
- Auditors as watchdogs

Early Origins of Auditing (Pre-1900)

- Auditing in ancient civilizations
- Used by kings, churches, and merchants
- Focus on cash and stewardship

Limitations of Early Auditing

- Time consuming
- Inefficient for large entities
- Limited business insight
- Reactive rather than proactive

Industrial Revolution (1900–1930)

- Growth of corporations
- Separation of ownership and management
- Need for independent audits

Development of Professional Bodies

- Formation of accounting institutes
- Standardization of practice
- Recognition of auditors as professionals

Shift in Audit Objective

- From fraud detection
- To verification of financial statements
- True and fair view concept

Great Depression & Regulation (1930s)

- Corporate collapses
- Loss of investor confidence
- Government intervention

Standards and Internal Control Era (1930–1960)

- Introduction of audit standards
- Reliance on internal control systems
- Audit planning

Audit Sampling

- Testing samples instead of all transactions
- Statistical and judgmental sampling
- Improved efficiency

Internal Control Concept

- Policies and procedures
- Safeguard assets
- Ensure reliable reporting
- Prevent and detect errors

Risk-Based Auditing (1970–1990)

- Complex business environments
- Focus on audit risk
- Efficient allocation of audit effort

Components of Audit Risk

- Inherent risk
- Control risk
- Detection risk

Emergence of Assurance Services

- Stakeholders demand more than financial audits
- Need assurance on systems and processes
- Expansion of auditor role

Benefits of Risk-Based Auditing

- Cost-effective audits
- Better focus on material areas
- Improved audit quality

Corporate Scandals (2000–2010)

- Enron
- WorldCom
- Parmalat

Impact of Corporate Scandals

- Loss of public trust
- Failure of self-regulation
- Stricter laws

Difference Between Auditing and Assurance

- Audit focuses on financial statements
- Assurance covers broader information
- Audit is a subset of assurance

Sarbanes-Oxley Act (SOX)

- Strengthened internal controls
- Auditor independence
- Management responsibility

Types of Assurance Services

- Internal control assurance
- Compliance assurance
- ICT and systems assurance
- Sustainability assurance

Modern Auditing (2010–Present)

- Technology-driven audits
- Use of data analytics
- Continuous auditing

ICT Assurance

- Cybersecurity audits
- System reliability
- Data privacy and protection

Role of Technology in Auditing

- Computer Assisted Audit Techniques (CAATs)
- Big data analytics
- Artificial intelligence

Sustainability & ESG Assurance

- Environmental, social, and governance- ESG
  - Environmental reporting
  - Social responsibility
  - Governance assurance

Integrated Reporting Assurance

- Financial and non-financial information
- Value creation
- Long-term sustainability

Financial Audit

- Focuses on accuracy of financial statements
- Ensures compliance with accounting standards (e.g., IFRS)
- Deals with financial records and reporting
- Objective: Assurance on financial fairness

Future of Auditing and Assurance

- Continuous assurance
- AI-driven audits
- Greater focus on ICT and sustainability

IT Audit

- Focuses on information systems and technology controls
- Evaluates security, data integrity, and system efficiency
- Covers hardware, software, networks, and data
- **Objective: Secure and effective IT systems**

Key Differences: Financial vs IT Audit

- Financial audit = money and reporting
- IT audit = systems and data security
- Different skill sets and tools used
- Both support organizational accountability

CIA Triad Overview

- **Confidentiality, Integrity, Availability**
  - Foundation of information security
  - Ensures protection and usability of data

Role of IT Audit in Organizations

- Evaluates IT controls
- Ensures data security and protection
- Assesses system reliability and availability
- Supports regulatory compliance
- Identifies risks and recommends improvements

Confidentiality

- Access only to authorized users
- Techniques: encryption, passwords, access control

Integrity

- Ensures data accuracy and trustworthiness
- Techniques: hashing, validation, checksums

Lecture Summary

- Auditing evolved with business needs
- Shift from fraud detection to assurance
- Technology shaping the future

Availability

- Ensures systems/data accessible when needed
- Techniques: backups, redundancy, disaster recovery

Discussion Questions

- Why did auditing move beyond fraud detection?
- How has ICT changed auditing?
- Is assurance more important than auditing today?

RESEARCH

Carry out research on the following corporate scandals:

- Enron
- WorldCom
- Parmalat

Internal Control- What is it?

- Process implemented by management and staff
- Provides reasonable assurance in achieving objectives
- Applies to operations, reporting, and compliance
- Involves policies, procedures, and activities
- Helps prevent fraud, errors, inefficiencies
- Continuous and dynamic process

Reference

- Information Technology Control and Audit.

Angel Otero. 5edn

Objectives of Internal Control

- **Operational:** Efficient and effective resource use
- **Reporting:** Accurate, reliable, timely information
- **Compliance:** Adherence to laws and policies

Principles of Internal Control

- Segregation of duties
- Authorization
- Documentation
- Physical controls
- Independent checks
- Monitoring

Internal Controls in Information Systems

- Types:
  - Preventive (e.g., passwords)
  - Detective (e.g., logs)
  - Corrective (e.g., backups)
- General vs application controls

Internal Control Models

- **COSO**: Control Environment, Risk Assessment, Control Activities, Information & Communication, Monitoring
- **COBIT**: IT governance and alignment
- **ISO 31000**: Risk management guidelines

Importance of Internal Control

- Enhances accountability and transparency
- Reduces fraud and errors
- Improves decision-making
- Ensures compliance
- Strengthens performance

Information Technology Governance

- IT governance ensures IT supports business goals
- Focuses on value delivery, risk management, and performance
- Aligns IT strategy with organizational objectives
- Defines decision rights and accountability
- Uses frameworks like COBIT and ISO/IEC 38500
- Promotes transparency and compliance

Structure of the IT Function

- **Centralized Structure**
  - IT decisions controlled at top level
  - Ensures standardization and control
- **Decentralized Structure**
  - IT decisions distributed across departments
  - Increases flexibility and responsiveness
- **Hybrid Structure**
  - Combination of centralized and decentralized
  - Balances control and flexibility

Objectives of IT Governance

- Ensure **alignment** between IT and business strategy
- Deliver value from IT investments
- Manage IT-related risks effectively
- Optimize resource utilization
- Measure IT performance and outcomes

Key Roles in IT Function

- **Chief Information Officer (CIO)** – Strategic IT leadership
- **IT Managers** – Oversee operations and projects
- **System Administrators** – Maintain IT systems
- **Network Administrators** – Manage networks
- **Security Officers** – Ensure cybersecurity
- **End Users** – Use systems for daily operations

Disaster Recovery Planning (DRP)

- DRP is a plan to restore IT systems after disruption
- Covers events like cyberattacks, hardware failure, natural disasters
- Ensures business continuity
- Includes backup, recovery procedures, and responsibilities
- Focus on minimizing downtime and data loss

Discussion

- Develop Disaster Recovery Plan for a bank and a University. What overlaps exist and what differences did you consider?
- What are the Audit implications of IT Outsourcing?
- Explain the following internal controls and provide an example:
  - Preventive controls
  - Detective controls
  - Corrective controls

Key Components of DRP

- **Risk Assessment** – Identify potential threats
- **Business Impact Analysis (BIA)** – Determine critical systems
- **Backup Strategies** – Regular data backups
- **Recovery Procedures** – Step-by-step restoration
- **Testing and Updating** – Regular DRP testing
- **Communication Plan** – Clear roles during disaster

Audit Implications of IT Outsourcing

Outsourcing shifts IT functions to third-party providers

- Introduces risks (data security, loss of control, compliance issues)
- Requires vendor evaluation and due diligence
- Auditors assess service level agreements (SLAs)
- Review third-party controls (e.g., SOC reports)
- Ensure data protection and regulatory compliance

Key Audit Considerations

- Access controls at vendor level
- Data **confidentiality** and **integrity**
- Service **availability** and reliability
- Compliance with laws and contracts
- Monitoring and performance reviews

IT Risk Management – Overview

IT Risk Management is the process of identifying, assessing, and controlling risks affecting Information Systems

- Ensures protection of organizational data and IT assets
- Supports business continuity and decision-making
- Aligns IT risks with organizational risk strategy

IT Risk Managment

Definition of IT Risk

IT Risk: The potential for loss or damage related to the use of information systems

Arises from:

- Security breaches
- System failures
- Human errors
- Natural disasters

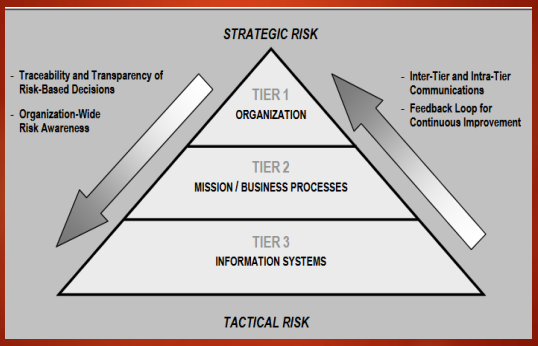
Formula (Risk Matrix):

- Risk = Threat × Vulnerability × Impact

IT Risks may include:

- Loss of data through accidental damage to computing equipment
- Loss of data through theft of storage devices
- Loss of data due to malfunctioning equipment
- Failure of IT equipment
- Network failure
- Hackers having unauthorised access to IT systems
- Intentional deletion of data
- Unavailability of critical IT staff (expertise)

Risk Management Hierarchy



Importance of IT Risk Management

- Protects sensitive data
- Ensures system reliability
- Supports compliance with laws and standards
- Minimizes financial and reputational loss

IT Risk Identification

Process of discovering potential threats to IT systems

Common sources:
- Cyberattacks (malware, hacking)
- Hardware/software failure
- Insider threats
- Environmental risks

Techniques:
- Risk assessments
- Interviews and questionnaires
- System analysis
- Historical data review

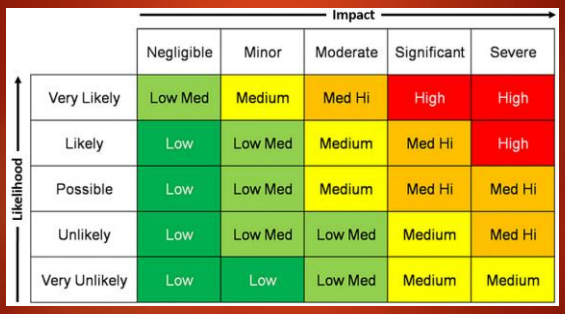
IT Risk Assessment

- Evaluates the **likelihood** and **impact** of identified risks
- Helps prioritize risks for action
- **Key components:**
  - Likelihood (Low, Medium, High)
  - Impact (Low, Medium, High)

Tools:

- Risk matrix
- Qualitative and quantitative analysis

Risk Matrix



Likelihood \ Impact	Negligible	Minor	Moderate	Significant	Severe
Very Likely	Low Med	Medium	Med Hi	High	High
Likely	Low	Low Med	Medium	Med Hi	High
Possible	Low	Low Med	Medium	Med Hi	Med Hi
Unlikely	Low	Low Med	Low Med	Medium	Med Hi
Very Unlikely	Low	Low	Low Med	Medium	Medium

Risk Matrix

- A tool used to rank risks based on likelihood and impact
- Helps in decision-making and prioritization

Example:

- High likelihood + High impact = Critical risk
- Low likelihood + Low impact = Acceptable risk

Risk Calculation

- **Risk = Threat × Vulnerability × Impact**
- In the context of Information Technology and cybersecurity auditing, this formula is the foundational equation for **Quantitative Risk Assessment**.
- It helps organizations **prioritize which security gaps** need the most immediate attention by assigning numerical or quantitative values to risk.

Example-Student Records Database

- Imagine we are assessing the risk of a **Data Breach** involving the university's central student information system.
- To apply the formula to a university environment, we often use a **Risk Matrix** (typically a 1–5 scale).
- This allows an IT auditor to visualize which risks require immediate budget allocation versus those that can simply be monitored.

The Calculation

- **Risk=4×3×5=60**
- In a system where the maximum possible score is 125 (5×5×5), a score of **60** usually triggers a "High Priority" status.

Risk Matrix

Variable	Rating (1-5)	Justification
Threat	**4 (High)**	Frequent phishing attempts targeting faculty and automated "bot" scans on the university network.
Vulnerability	**3 (Medium)**	The database has the latest patches, but some administrative staff have not completed their 2026 security awareness training.
Impact	**5 (Critical)**	A breach would result in a violation of data privacy laws, massive reputational damage, and potential loss of accreditation.

Risk Matrix (Solution)

- **Visualizing the Risk Matrix**
- Auditors often plot these results on **a heatmap** to show stakeholders where the "**Red Zone**" lies.
- **Mitigation Strategies**
- Based on this formula, the university has two options to lower the score of 60:
- **To Lower Vulnerability:** Mandatory multi-factor authentication (MFA) for all staff. This might drop the Vulnerability from a **3** to a **1**, reducing the total Risk to **20**.
- **To Lower Impact:** Implement "Data Masking" so that even if a breach occurs, the actual sensitive IDs are encrypted. This might drop the Impact from a **5** to a **2**, reducing the total Risk to **24**

IT Risk Mitigation

Strategies to reduce or manage risks:

- **Avoidance** – eliminate the risk
- **Reduction** – implement controls (e.g., firewalls)
- **Transfer** – outsource or insure
- **Acceptance** – tolerate low-level risks
- Focus on cost-effective controls

Summary



Risk Controls Examples

- **Technical controls:**
  - Firewalls, antivirus, encryption
- **Administrative controls:**
  - Policies, training, procedures
- **Physical controls:**
  - Locks, surveillance, access cards

Summary

IT Risk Management involves:

- Identification
- Assessment
- Mitigation
- Continuous process requiring monitoring and improvement
- Critical for organizational success

Questions

1. Develop a risk register for a small IT organisation
2. Explain the potential risk response decisions at the **Information Systems** tier of the risk management hierarchy
3. Discuss the **non security** related risk management activities across the hierarchy that benefit from risk assessments
4. Discuss the relationship between the three-tier risk management hierarchy and the typical three level management organization

References

- NIST. Guide for Conducting Risk Assessment https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-30r1.pdf
- Conducting an IT Security Risk Assessment- ISACA
- https://www.cybok.org/
- https://www.isaca.org/resources/it-risk

Risk Register

Risk ID	Risk Description	Threat Source	Likelihood	Impact	Risk Level	Existing Controls	Mitigation Strategy	Owner	Status
R1	Data breach due to weak passwords	Cyber attackers	High	High	Critical	Password policy	Enforce strong passwords, MFA	IT Manager	Open
R2	Malware infection								
R3	System downtime								
R4	Data loss								
R5	Unauthorized access								
R6	Network breach								
R7	Software vulnerabilities								
R8	Human error								
R9	Theft of equipment								
R10	Compliance violation								

IT Governance Frameworks

IT Governance

- IT governance is a framework that **aligns** an organization's **IT strategy** with its overall **business goals**, ensuring technology investments support business objectives, manage risks, and maximize value.
- It sets the structure for directing and controlling IT, balancing performance and compliance with regulatory standards

Key Objectives of IT Governance

- **Strategic Alignment:** Ensuring IT initiatives and business strategies are in sync.
- **Value Delivery:** Ensuring IT delivers promised benefits on time and within budget.
- **Risk Management:** Identifying and reducing IT-related risks, such as security threats and system failures.

Benefits of IT Governance

- Effective IT governance reduces technical failures and security breaches, ensures compliance with regulations like GDPR or HIPAA, and ensures accountability and transparency in IT investments

Objectives- contd

- **Resource Management:** Optimizing the use of IT resources, including infrastructure and personnel.
- **Performance Monitoring:** Using Key Performance Indicators (KPIs) to ensure IT meets organizational needs.

IT Governance Standards

- IT governance standards are structured frameworks, principles, and best practices that guide how an organization **directs** and **controls** its **IT resources** to ensure **alignment** with **business goals**, manage risks, and create value.
- They provide a roadmap for accountability, compliance, and effective technology performance

COBIT- Control Objectives for Information and Related Technology

- A globally recognized framework for the **Governance and Management of Enterprise IT**.
- **Core Focus:** Aligning IT goals with business goals to ensure value creation and risk mitigation.

IT Governance Standards

Framework	Primary focus	Organization	Target audience
COBIT 2019	Overall IT governance and management	ISACA	Executives, auditors, CIOs
ITIL 5	IT service management	Axelos / PeopleCert	Operational teams, ITSM
TOGAF	Enterprise architecture	The Open Group	Architects, IS planners
ISO/IEC 38500	IT governance principles	ISO	Executive management
CMMI	Process maturity	ISACA (CMMI Institute)	Development teams

Key Principles:

- **Separation of Governance and Management:** Governance (Board/Direct) vs. Management (Executive/Execute).
- **End-to-End Coverage:** Treats IT as an asset that permeates the entire organization, not just the IT department.
- **Holistic Approach:** Utilizes enablers like processes, organizational structures, and culture

ISO/IEC 38500 Principles

- The international standard for the **Corporate Governance of IT**.
- It provides a high-level framework for directors to evaluate, direct, and monitor IT use.

The Six Principles:

4. Performance: IT systems must support the business and meet service levels.

5. Conformance: IT must comply with all mandatory legislation and regulations.

6. Human Behavior: Policies must respect the needs of all people involved in the process.

The Six Principles:

1. Responsibility: Clearly defined roles for IT supply and demand.

2. Strategy: IT must support the organization's future business needs.

3. Acquisition: IT investments are made based on business cases with balanced risks/benefits.

ITIL (Information Technology Infrastructure Library) Lifecycle

- A framework focused on **IT Service Management (ITSM)** to ensure IT services align with business needs.

The 5 Stages of the Lifecycle:

- **Service Strategy:** Defining the market and how to provide value.
- **Service Design:** Designing new or changed services (architecture, processes, policies).
- **Service Transition:** Building, testing, and deploying services into "live" operation.
- **Service Operation:** Day-to-day management of services and resolving incidents.
- **Continual Service Improvement (CSI):** Using quality management to learn from successes and failures.

Discussion

- What is the role of AI in IT governance ?

Comparison Table

Feature	COBIT	ISO/IEC 38500	ITIL
Primary Focus	Governance & Management	Corporate Governance	IT Service Management (ITSM)
Target Audience	Management & Audit	Board of Directors	IT Practitioners & Ops
Approach	Goal-driven (Top-down)	Principle-based	Process-driven (Lifecycle)
Key Question	"What is required to be done?"	"Is IT being governed well?"	"How do we deliver services?"
Flexibility	High (Modular)	Very High (Broad)	Specific (Best Practices)

References

- https://www.ibm.com/think/topics/it-governance
- https://www.isaca.org/resources
- https://www.itil.com
- https://www.coso.org/guidance-on-ic
- https://www.iso.org/standard/81684.html

Audit Planning and Methodology

CYS 491

Reasons to follow a Methodology

- Ensures Comprehensive Coverage
- Consistency and Repeatability
- Risk-Based Prioritization
- Professional Credibility and Compliance
- Efficient Resource Management
- Better Communication with Management

Methodology

- ***'a system of methods followed consistently.'***
- Following a methodology in IT auditing is like having a GPS for a complex journey. Without it, you might eventually reach your destination, but you'll likely waste fuel, hit dead ends, and miss critical landmarks along the way.

Audit Lifecycle – Planning

- Define audit objectives and scope
- Understand the organization and its environment
- Identify key risks and controls
- Develop audit plan and schedule
- Allocate resources and responsibilities

Audit Lifecycle – Fieldwork

- Execute audit procedures
- Collect and analyze evidence
- Test controls and systems
- Document findings and observations
- Maintain working papers

Audit Lifecycle – Follow-up

- Review implementation of recommendations
- Monitor corrective actions
- Ensure issues are resolved
- Conduct follow-up audits if necessary
- Report status to management

Audit Lifecycle – Reporting

- Summarize audit findings
- Evaluate control effectiveness
- Provide recommendations
- Prepare audit report
- Communicate results to stakeholders



Audit Evidence Collection Techniques

- **Inspection** (documents, records)
- **Observation** (processes, activities)
- **Inquir**y (interviews, questionnaires)
- **Re-performance** (independent testing)
- **Analytical procedures** (data analysis)

Why Sampling is used in Audits

- **1. Efficiency: Saving Time & Cost**
- **Eliminates Bottlenecks:** Auditing every record is prohibitively expensive and slow.
- **Strategic Focus:** Shifts resources from "checking boxes" to analyzing a representative subset.
- **Feasibility:** Makes comprehensive audits possible within tight deadlines.

Sampling Methods

Selecting a subset of data for testing
Types:
- Random sampling
- Systematic sampling
- Stratified sampling
- Judgmental sampling

Purpose:
- Reduce time and cost
- Improve efficiency
- Ensure sample is representative

Why Sampling is used in Audits

- **2. Managing Massive Data Volumes**
- Handles modern business environments with millions of transactions.
- Provides a realistic alternative to the impossible task of 100% data review.
- Ensures no area is left completely unexamined despite the scale.

Why Sampling is used in Audits

- **3. Statistical Validity & Reliability**
- Uses mathematically sound techniques to draw conclusions about the whole population.
- Supports the audit opinion with statistically valid results.
- Meets rigorous international auditing standards (e.g., ISA).

Why Sampling is used in Audits

5. Provides Strong Audit Evidence

- Sampling provides sufficient and appropriate **audit evidence**
- Helps verify:
- Accuracy of financial records
- Effectiveness of controls
- Strengthens the credibility of audit findings

Why Sampling is used in Audits

- **4. Risk-Based Prioritization**
- **Targeted Auditing:** Allows auditors to focus on "high-risk" areas prone to error or fraud.
- Dedicates more effort to where the stakes are highest.
- Catches significant issues faster than a random or total review.
- Improves **audit effectiveness**

Why Sampling is used in Audits

6. Practicality and Efficiency

- Enables auditors to complete work within **limited timeframes**
- Balances **accuracy and efficiency**
- Widely accepted in auditing standards (e.g., ISA)



Auditing IT Infrastructure

Assignment

- Design internal controls for a student information system

Auditing IT Infrastructure

- KEY⟶ Ensuring security, reliability, and compliance
- Key areas: OS, Network, Database, Cloud, Data Centers

Auditing IT Infrastructure

- An IT infrastructure audit is a comprehensive evaluation of an organization's hardware, software, networks, and security protocols to ensure reliability, security, and efficiency.
- It identifies risks like outdated software, weak security, and performance bottlenecks, which helps align technology with business goals and ensures compliance with standards

Objectives of IT Infrastructure Audit

- Protect organizational assets
- Ensure system availability and reliability
- Verify compliance with regulations
- Improve operational efficiency
- Detect and prevent security breaches

What is IT Infrastructure Auditing?

- Evaluation of IT systems, controls, and operations
- Ensures:
  - Security of systems
  - Data integrity
  - Compliance with policies and standards
- Identifies risks and vulnerabilities

Operating Systems Audit

- Review OS configuration and security settings
- Check:
  - User accounts and permissions
  - Patch management and updates
  - System logs and monitoring
- Identify unauthorized access or vulnerabilities

Operating Systems Audit (Key Controls)

- Strong password policies
- Access control mechanisms
- Regular updates and patching
- Antivirus and endpoint protection
- Audit trails and logging

Network Audit (Key Areas)

- Firewall rules and configurations
- Intrusion detection/prevention systems (IDS/IPS)
- Network segmentation
- Wireless network security
- Vulnerability assessments

Network Audit

- Evaluation of network infrastructure and security
- Review:
  - Network devices (routers, switches, firewalls)
  - Network configurations
  - Traffic monitoring

Database Audit

- Ensures data integrity, confidentiality, and availability
- Review:
  - Database access controls
  - User roles and privileges
  - Backup and recovery processes

Database Audit (Key Controls)

- Data encryption
- Regular backups
- Activity monitoring and logging
- Patch updates
- Prevention of SQL injection and attacks

Cloud Audit (Key Risks)

- Data breaches
- Misconfigured cloud storage
- Weak access controls
- Vendor lock-in
- Lack of visibility and control

Cloud Computing Audit Considerations

- Shared responsibility model
- Evaluate:
  - Data security and privacy
  - Access management (IAM)
  - Vendor compliance and certifications

Data Center Controls

- Physical and environmental security
- Controls include:
  - Access control (biometric, card access)
  - Surveillance (CCTV)
  - Fire suppression systems

Data Center (Environmental Controls)

- Temperature and humidity control
- Power backup (UPS, generators)
- Disaster recovery plans
- Redundancy systems

Summary

- IT audits cover multiple layers of infrastructure
- Key focus areas:
  - Operating systems
  - Networks
  - Databases
  - Cloud environments
  - Data centers
- Continuous auditing is essential

Importance of IT Infrastructure Auditing

- Reduces risks and vulnerabilities
- Enhances system performance
- Builds stakeholder confidence
- Supports regulatory compliance

Discussion Questions

- What is the biggest risk in cloud environments?
- How can organizations improve audit effectiveness?
- Why is physical security still important today?

Case Study Reflection

- What surprised you most?
- Which area is often ignored in real life?
- How can audits prevent disasters?